KODIGO

Kodigo System Design and Governance

Technical design and accountable governance for the Kodigo capstone system

Table 1. Document Control

Control	Value
Version / effective date	Version 1.8 | 12 October 2026
Status	FINAL — owner-issued for SWU-002 academic submission, 12 October 2026. The deployed public URL is recorded; proposed groups are explicitly labeled. No further document approval is pending.
Document owner / author	Evon Christian P Vergara | Course group SWU-002
Client stakeholder	Ira Pongasi (client stakeholder)
Course / group	Managing IT Resources — SWU-002 (academic project).
Prepared by	Evon Christian P Vergara, Project Owner
Reviewed	Teacher-marked peer-review rubric/revision notes dated 6 October 2026 incorporated; the review audit is complete.
Endorsed	N/A — no external endorsement was requested or provided for this owner-issued academic edition.
Approved / issued by	Evon Christian P Vergara, Document Owner — final owner-issued edition, 12 October 2026.
Review cycle	Review annually and after material changes to roles, privacy, system behavior, or operating conditions.
Evidence basis	Project source and local demo checked 12 October 2026. The public production login page at https://kodigo-blue.vercel.app/ was observed on 12 October 2026; authenticated workflows, database migration state, provider groups, and backup settings were not inspected. Embedded interface captures dated 15 September 2026 are redacted.

Revision history: v1.8 (12 October 2026) - added a system data-item classification and protection-level matrix; clarified the personal-data breach assessment, decision authority, and notification procedure; and grouped links to the related policies and user guidance. v1.7 (12 October 2026) - recorded the owner-reported production deployment and observed public login page; added clearly proposed PROD, UAT, and TEST access-group matrices including System Administrator; stated the required Admin/Super Admin MFA policy with source-enforcement limits; and linked a companion proposed operations runbook. v1.6 (12 October 2026) - added repository schema metadata and a visual operating-process diagram. v1.5 (12 October 2026) - added proposed outcomes, thesis-aligned test ownership and timing, and role-specific user profiles; test results remain unverified. v1.4 (12 October 2026) - incorporated teacher revision notes and reviewed the local demo. v1.3 (5 October 2026) - previous owner-issued edition.

Contents

Contents 2
Executive summary 3
PART I - SYSTEM DESIGN 3
1. Purpose, business need, scope, and stakeholders 3
2. Objectives and acceptance criteria 4
3. Architecture and major components 5
4. Technology choices and rationale 5
5. Major modules and functional requirements 6
6. Data model and relationships 6
7. Data flow and business process 8
8. Role and permission design 8
9. Security architecture and risk controls 10
10. Integrations, environments, and service identities 10
PART II - SYSTEM GOVERNANCE 11
11. Governance objectives and structure 11
12. Decision rights and segregation of duties 12
13. Access governance lifecycle 12
14. Data and privacy governance 12
Breach assessment and notification procedure 13
Data classification and protection levels 14
15. Risk management 14
16. Change, release, and configuration management 15
17. Incident management and escalation 16
18. Backup, recovery, audit, and monitoring responsibilities 17
19. User feedback and post-launch improvement 17
20. Documentation ownership, training, and review 18
21. Feasibility, rollout sequence, and resource plan 18
Appendix A. Redacted interface captures 20

Executive summary

Kodigo is a multi-store retail operations system for sari-sari stores and small branches. It combines browser-based checkout, catalog and stock controls, supplier and purchase-order workflows, reporting, and store-level access management. The design uses a React and TypeScript frontend with Supabase Auth and Postgres, database-enforced store scoping, server-side functions for privileged administration, and browser storage for eligible offline work. This document separates technical design from governance so reviewers can see both how the system works and who must control it.

This final owner-issued edition records the deployed public entry point and source-verified design. The public login page was observed at https://kodigo-blue.vercel.app/ on 12 October 2026; authenticated production workflows, database migration state, account groups, and backup settings were not independently inspected.

PART I - SYSTEM DESIGN

1. Purpose, business need, scope, and stakeholders

Small retailers need checkout, stock records, supplier coordination, and simple performance reporting to stay aligned across daily work. When sales and inventory records are separated, cashiers may repeat a payment, staff may reorder from stale stock, and owners may be unable to trace a correction. Kodigo addresses this operational need by linking sale records to product stock, preserving transaction lifecycle events, showing stock alerts and restocking information, and summarizing activity by store.

Client and project contacts

Stakeholder / role	Organization	Contact	Authority / status
Ira Pongasi — client stakeholder	N/A – To be provided	N/A – To be provided	Named by Evon Christian P Vergara; no client endorsement is implied.
Evon Christian P Vergara — Project Owner, SWU-002	Kodigo capstone project	vergaraevon@gmail.com	Document owner and project-support contact.

Table 2. System purpose and boundaries

Item	Description
Purpose	Support checkout, inventory accuracy, supplier procurement, and store-level review for small retail operations.
Primary users	**Admin —** Manages assigned-store users, products, suppliers, settings, reports, and day-to-day store operations as needed, typically daily. Uses a Windows 11 desktop or laptop with a current Chrome or Edge browser. **Cashier —** Processes checkout, records the configured payment method, provides receipts, and completes shift handoff each shift. Uses a Windows 11 desktop or laptop with a current Chrome or Edge browser; scanner or cash drawer only where compatible. **Inventory —** Maintains product and stock records, records receiving and adjustments, and reviews inventory reports during deliveries, scheduled counts, or adjustments. Uses a Windows 11 desktop or laptop with a current Chrome or Edge browser; scanner only where compatible. **Super Admin —** Creates or manages owner invitation codes only when owner onboarding or invite maintenance is required; does not perform routine store operations. Uses a Windows 11 desktop or laptop with a current Chrome or Edge browser.
In scope	Browser application, Supabase Auth, Postgres data and policies, database functions and triggers, Edge Functions, browser offline storage offline queues, reports, and optional cash-drawer integration.

Item	Description
Out of scope unless separately confirmed	Card processing, storing full payment credentials, a mobile device management service, automated legal/tax certification, a named production service desk, or verified production hosting and backups.

2. Objectives and acceptance criteria

These are proposed outcomes, not reported results. The thesis schedules functional testing for 16 March-15 April 2026, controlled deployment for 16 April-15 May 2026, and evaluation and closure (including user acceptability and security validation) for 16 May-15 July 2026. The scheduled overall completion target is 15 July 2026. Evon Christian P Vergara is the test lead, responsible for coordination and evidence recording; selected users perform role-based workflows; qualified IT evaluators conduct independent technical validation. The thesis dates have elapsed as of 12 October 2026, and test logs or outcome evidence were not supplied. Completion of every objective below therefore remains unverified.

Table 3. Objectives and proposed acceptance measures

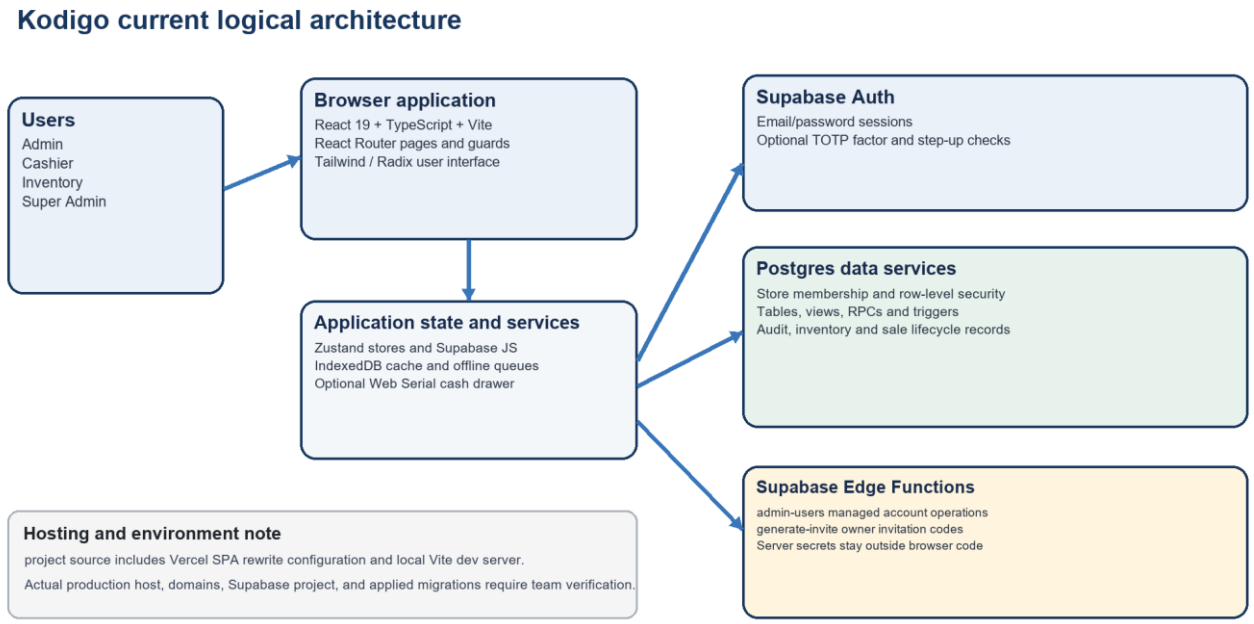
Objective / outcome	Proposed success measure and target date	Test owner and thesis window	Evidence and status
Pilot stock accuracy	Zero unexplained stock-count mismatches at the selected pilot store for 30 consecutive days, by 15 May 2026. Pilot store and result are unverified.	Selected Inventory users count; Admin reconciles; Evon (test lead) coordinates. Controlled deployment: 16 Apr-15 May 2026.	Daily count and reconciliation log. Pilot details and outcome unverified; date elapsed.
Role and store boundaries	All four roles perform permitted actions; every unauthorized cross-store read/write attempt is denied, by 15 Apr 2026.	Evon (test lead) with the project research team. Functional testing: 16 Mar-15 Apr 2026.	Sanitized role/store test matrix and results. Completion unverified; date elapsed.
POS correctness	At least 20 representative checkout cases produce correct totals, receipt references, and stock effects, with zero duplicate transactions, by 15 Apr 2026.	Evon (test lead) with the project research team. Functional testing: 16 Mar-15 Apr 2026.	Synthetic test cases, sale references, and reconciliation. Completion unverified; date elapsed.
Offline recovery	Five controlled offline/reconnection cases reach their expected final state after replay, with no lost or duplicate records, by 15 Apr 2026.	Evon (test lead) with the project research team. Functional testing: 16 Mar-15 Apr 2026.	Queue states and reconciliation log. Completion unverified; date elapsed.
Inventory and purchasing	Ten product, adjustment, receiving, archive, and supplier scenarios match their expected base-unit balances, by 15 Apr 2026.	Evon (test lead) with the project research team. Functional testing: 16 Mar-15 Apr 2026.	Scenario checklist and movement records. Completion unverified; date elapsed.
Role-based user readiness	At least one available representative for each role completes assigned workflow scenarios without an unsafe posting error, by 15 Jul 2026.	Selected users perform scenarios; Evon observes and records. Evaluation and closure: 16 May-15 Jul 2026.	Attendance and role-based scenario results. Participants and outcome unverified; date elapsed.

Objective / outcome	Proposed success measure and target date	Test owner and thesis window	Evidence and status
Technical and security validation	Qualified IT evaluators complete and record ratings for authentication, role-based access, data integrity, centralized synchronization, and secure data handling; each finding receives a disposition, owner, and due date, by 15 Jul 2026.	Qualified IT evaluators conduct the independent review; Evon coordinates and records. Evaluation and closure: 16 May-15 Jul 2026.	Completed validation survey and finding log. Evaluators and outcome unverified; date elapsed.
Recovery readiness	Complete one isolated restore rehearsal and reconcile stores, products, sales, sale items, and stock adjustments; record smoke-test results by 15 Jul 2026.	Evon (test lead) coordinates; an authorized technical maintainer executes; an independent reviewer checks evidence. Evaluation and closure: 16 May-15 Jul 2026.	Restore log, reconciliation counts, and reviewer record. Technical operator and outcome unverified; date elapsed.

3. Architecture and major components

The browser presents route-level screens and controls. Zustand stores manage session, active store, products, suppliers, cart, and alerts. The Supabase JavaScript client connects authenticated users to the backend. Supabase Auth issues sessions; Postgres policies constrain data; database functions and triggers carry business operations; Edge Functions perform privileged user and invite actions. Browser offline storage holds a product cache and eligible offline queues. Web Serial is optional and limited to a compatible cash-drawer command.

Figure 1. Kodigo Logical Architecture



4. Technology choices and rationale

Table 4. Technology stack and design reason

Layer	Current implementation	Reason for use / constraint
Frontend	React 19, TypeScript 5.9, Vite 7	Component-based interactive UI, typed application contracts, fast local development/build. TypeScript does not replace server authorization.

Layer	Current implementation	Reason for use / constraint
Navigation and state	React Router 7, Zustand 5	Route organization and small focused stores for authentication, product, supplier, cart, and alert state.
UI and charts	Tailwind CSS 4, Radix UI primitives, Lucide React, Recharts 3	Consistent responsive controls, accessible UI primitives, and interactive business charts.
Backend	Supabase Auth, Postgres, row-level security, database operations, triggers, views, Edge Functions	Managed sign-in and relational storage; database policies and functions enforce rules close to data. Actual target project and plan require confirmation.
Offline	browser offline storage through idb	Browser-local product cache and queues support eligible work during connectivity interruptions; conflict resolution is limited and queues require careful reconciliation.
Hardware and exports	Web Serial for optional ESC/POS drawer command; jsPDF and write-excel-file for exports	Uses browser capabilities for optional peripherals and report output. Printer/drawer compatibility must be tested.
Hosting	Vercel SPA rewrite configuration is present in source; the owner reports deployment at https://kodigo-blue.vercel.app/.	Public login page observed on 12 October 2026. Authenticated production behavior, provider plan, release permissions, and hosting cost were not verified.

5. Major modules and functional requirements

Table 5. Implemented module requirements

ID / module	Current behavior supported by project source	Expected result
FR-01 Identity and store context	Email/password sign-in, invite-based owner registration, role resolution, assigned store loading, and role-based route routing.	A user sees only authorized screens and store data.
FR-02 POS and receipts	Search by name/SKU/barcode, cart, unit/bulk options, payment, receipt snapshot, and sales lifecycle actions through database functions.	Sale, sale items, payment details, and stock effects are recorded consistently.
FR-03 Offline continuity	Cache products; queue eligible sales and selected mutations in browser offline storage; attempt replay on reconnect or page activity.	Pending/error state remains visible for reconciliation; business rule errors are not silently treated as network failures.
FR-04 Product and inventory	Product/category maintenance, purchase and selling units, price history, stock adjustment and movement records, archive/restore, and consumption history.	Base stock and its history remain traceable; sold products are archived rather than deleted.
FR-05 Suppliers and purchasing	Supplier records and store links, product supplier assignments, restocking options, purchase orders, receiving functions, supplier scoring, and consignment lots/balances.	Delivery and supplier-owned stock can be distinguished and reviewed.
FR-06 Alerts and notifications	Stock and selling-option conditions create notifications with user read state; report-export and transaction events can be surfaced.	Authorized users can review operational notices for assigned context.
FR-07 Reporting and analytics	Sales and inventory reports, Excel/PDF export paths, revenue/profit/category/hour charts, transaction views, rankings, and velocity.	Users review filtered output and export only within their role.
FR-08 Administration	Store branding and settings, managed staff account operations through admin-users Edge Function, invite generation through generate-invite, password reset, TOTP management.	Authorized changes are attributed and limited to the required store scope.

6. Data model and relationships

The schema is relational and store-oriented. Most operational records carry a store identifier or reach a store through an approved mapping. Row-level security (RLS) means database policies decide which rows an authenticated user can read or change for each request.

Table 6. Core data entities

Domain	Entities evidenced in schema and migrations	Relationship / purpose
Identity and tenancy	`profiles`, `stores`, `store_users`, `invite_codes`	Profiles map to stores through store_users; role and membership scope access.
Catalog and stock	`categories`, `products`, `product_selling_options`, `product_restocking_options`, `stock_adjustments`, `inventory_movements`, `inventory_stock_lots`	Products belong to store/category; stock movements explain sales, receipt, loss, adjustment, and consignment allocation.
Sales	`sales`, `sale_items`, `sale_payments`, `receipts`, `sale_events`, `sale_returns`, `sale_return_items`, `cashier_closeouts`	A sale has line items, payment and receipt records, with lifecycle events for void/refund/return and closeout.
Procurement	`suppliers`, `supplier_stores`, `product_suppliers`, `purchase_orders`, `purchase_order_items`	Supplier-store links support shared suppliers; orders link suppliers and products to receiving events.
Operations and evidence	`notifications`, `notification_user_states`, `audit_logs`, `error_logs`, `receipt_reprints`, `product_price_history`	Operational notices, user read status, errors, audit evidence, reprints, and price history support monitoring and traceability.

The list reflects current application source migrations and application queries, not a verified live database inventory. The target project's applied migration ledger and actual grants must be inspected before release.

Database metadata: repository baseline schema snapshot (supabase_schema.sql); ordered Supabase migrations; repository migration index and numbered SQL files. The baseline snapshot is dated 2 March 2026 and may not include later source migrations. The deployed project migration ledger, live schema, grants, and policy state were not inspected; treat them as authoritative.

7. Data flow and business process

A named user is assigned a role and store, signs in, and confirms the active store. After access is checked, the user performs assigned work; online sales use the protected sale-processing RPC, while only eligible work may be queued locally during an interruption. Staff reconcile outcomes before closeout.

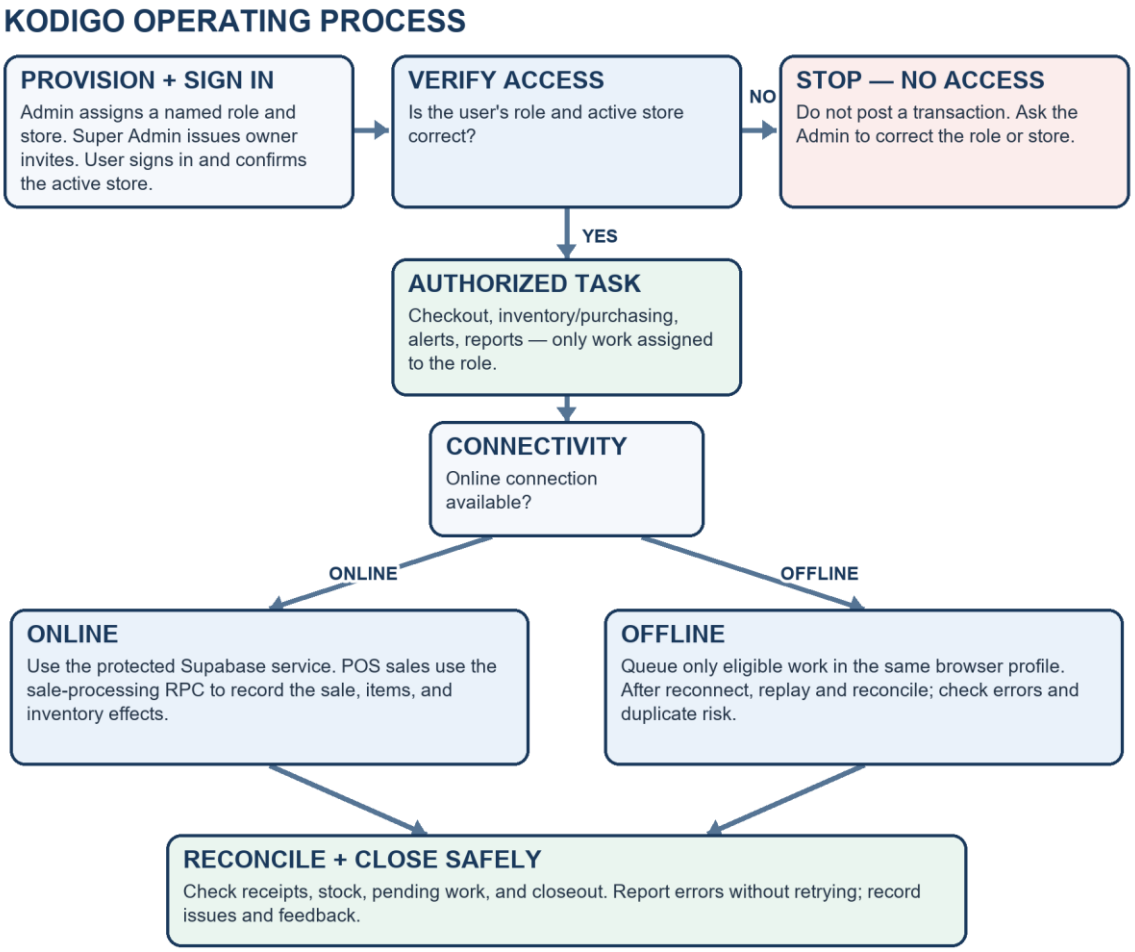


Figure 2. Kodigo operating process and offline-recovery flow

Flow summary: Provision role/store → sign in → verify access (stop before posting if incorrect) → complete assigned work online or queue eligible offline work → reconcile receipts, stock, pending work, and closeout.

8. Role and permission design

Table 7. Application permission matrix

Capability	Admin	Cashier	Inventory	Super Admin
POS checkout	Execute where enabled	Execute	None	None
Products and stock	Full store control	Read at POS	Manage within assigned scope	None
Stock adjustment / receiving	Manage and approve per local controls	None	Record within role and store scope	None
Suppliers and purchase orders	Manage assigned stores	None	No supplier administration	None
Dashboard / analytics / rankings	Assigned-store view	None	Limited per route	None
Reports	Sales and inventory	None	Inventory-oriented reports	None
Store settings / staff management	Manage assigned stores via supported controls	Own account	Own account	None

Capability	Admin	Cashier	Inventory	Super Admin
Invite governance	None	None	None	Generate owner invitation codes
Account security	Own account	Own account	Own account	Own account

This table summarizes application-role behavior in source; database policies remain authoritative. System Administrator is a technical identity, not an in-app business role. The proposed environment matrices below include its separate provider-console scope; it has no POS/business permissions by default. Production permissions still require validation against the deployed migration state.

Environment-specific access matrices (group names below are proposed examples, not verified or provisioned)

Table 8. Proposed PROD access matrix

Proposed group name	Role	Intended access scope	Verification status
KODIGO_PROD_ADMIN	Admin	Assigned-store operations and supported staff/catalog controls.	Proposed name only; provisioning and membership unverified.
KODIGO_PROD_CASHIER	Cashier	Checkout, receipts, and assigned shift tasks for the active store.	Proposed name only; provisioning and membership unverified.
KODIGO_PROD_INVENTORY	Inventory	Catalog, counts, receiving, and adjustments within assigned scope.	Proposed name only; provisioning and membership unverified.
KODIGO_PROD_SUPER_ADMIN	Super Admin	Owner invitation governance; no routine store operations.	Proposed name only; provisioning and membership unverified.
KODIGO_PROD_SYSADMIN	System Administrator	Separate named technical access to approved Vercel/Supabase control-plane tasks; no application business role by default.	Proposed name only; technical identity and access unverified.

Table 9. Proposed UAT access matrix

Proposed group name	Role	Intended access scope	Verification status
KODIGO_UAT_ADMIN	Admin	User-acceptance workflows within the assigned test store.	Proposed name only; UAT project and membership unverified.
KODIGO_UAT_CASHIER	Cashier	Checkout/receipt acceptance tests using approved synthetic or masked data.	Proposed name only; UAT project and membership unverified.
KODIGO_UAT_INVENTORY	Inventory	Catalog, count, receiving, and adjustment acceptance tests.	Proposed name only; UAT project and membership unverified.
KODIGO_UAT_SUPER_ADMIN	Super Admin	Invitation governance tests only, using approved test identities.	Proposed name only; UAT project and membership unverified.
KODIGO_UAT_SYSADMIN	System Administrator	Technical access to the isolated UAT provider project only.	Proposed name only; technical identity and access unverified.

Table 10. Proposed TEST access matrix

Proposed group name	Role	Intended access scope	Verification status
KODIGO_TEST_ADMIN	Admin	Functional and role/store tests in an isolated synthetic-data project.	Proposed name only; TEST project and membership unverified.
KODIGO_TEST_CASHIER	Cashier	Checkout, receipt, and transaction-lifecycle tests with synthetic data.	Proposed name only; TEST project and membership unverified.

Proposed group name	Role	Intended access scope	Verification status
KODIGO_TEST_INVENTORY	Inventory	Inventory, receiving, adjustment, and offline-replay tests.	Proposed name only; TEST project and membership unverified.
KODIGO_TEST_SUPER_ADMIN	Super Admin	Invitation-governance tests using test-only identities.	Proposed name only; TEST project and membership unverified.
KODIGO_TEST_SYSADMIN	System Administrator	Technical access to the isolated TEST provider project only.	Proposed name only; technical identity and access unverified.

9. Security architecture and risk controls

Table 11. Security controls classified by purpose

Control class	Control evidenced or required	Risk addressed / evidence
Preventive	Supabase Auth sessions; role checks; store membership; row-level security; authorized RPC checks.	Blocks unauthorized access and cross-store operations; validate with role/store test cases.
Preventive	Owner-confirmed policy: MFA is required and implemented for Admin and Super Admin. Source includes TOTP enrollment, challenge verification, and AAL2 checks for verified factors. The migration allows AAL1 without a verified factor; confirm the first-factor enrollment gate in the deployed configuration.	Reduces account takeover. Production account settings and first-factor enrollment enforcement were not independently inspected.
Preventive	Server-side admin-users and generate-invite functions; service-role secrets stay in server environment.	Limits privileged user-management operations; verify only required secrets are configured and never expose them in VITE variables.
Preventive	Store-specific active context for POS; database sale/receive/adjustment database operations; validation and lifecycle rules.	Reduces wrong-store posting and direct stock mutation.
Detective	`audit_logs`, `sale_events`, `inventory_movements`, `error_logs`, closeouts, price history, and export notifications.	Supports accountability and incident reconstruction; retention, access review, and alert ownership must be assigned.
Detective	Quarterly role/store review and release/test evidence.	Detects stale or excessive privileges and unsafe changes; retain dated approval records.
Corrective	Revoke or change access, reset credentials, correct through traceable adjustment/return functions, and preserve error queues.	Contains compromise and repairs records without concealing prior events.
Corrective	Proposed backup and restore steps are in the companion KodiGo Operations Runbook.	Recovery depends on configured backups and a successful restore drill; production backup settings and restore evidence were not provided.

10. Integrations, environments, and service identities

Table 12. Environment and identity inventory

Environment / identity	Current configuration or account group	Access and data boundary	Status / verification
Local demo	http://localhost:5173/; Vite development server on the owner workstation. Application roles: admin, cashier, inventory, super_admin.	Use synthetic records only; localhost is reachable on that computer only.	Observed in the local demo on 12 October 2026; not a public or production URL.
TEST	Proposed TEST groups appear in Table 10; application source includes test tooling.	Synthetic accounts and isolated test data only; do not connect test identities to production.	TEST project URL, deployed migration state, group provisioning, membership, and test roster were not verified.
UAT	Proposed UAT groups appear in Table 9; no UAT endpoint was supplied.	Keep UAT separate from production; use synthetic or specifically approved masked data.	UAT project, URL, provider groups, membership, and data controls were not verified.

Environment / identity	Current configuration or account group	Access and data boundary	Status / verification
PROD	Owner-reported deployment: https://kodigo-blue.vercel.app/	Named application accounts and store-scoped permissions are intended. The live data set, Supabase project identity, provider roles, and group membership were not inspected.	Public /login page observed on 12 October 2026. Authenticated transactions, deployed migrations, and production access controls were not independently tested.
Browser client	VITE_SUPABASE_URL and VITE_SUPABASE_ANON_KEY are public browser configuration values.	Only the public/anon key may be shipped to the browser; database policies enforce access.	No client secret may be placed in VITE variables or browser bundles.
Server functions and backups	admin-users and generate-invite functions are present in source; the companion runbook proposes backup and restore procedures.	Keep service-role secrets server-side; restrict control-plane access; never put secrets in VITE variables or browser bundles.	Production function deployment, named service identities, backup plan, retention, and restore evidence remain unverified.

Migration caution: the current application source contains numbered migrations through migration_40 and additional dated migrations. The README setup sequence does not include every newest file. Treat the applied migration ledger in the target Supabase project as the deployment source of truth; do not assume current application source files are already deployed or invent an execution order where the environment is unknown.

PART II - SYSTEM GOVERNANCE

11. Governance objectives and structure

Governance assigns decision rights for access, changes, data, security, incidents, backups, and documentation. The deploying organization owns the service and accepts operational and privacy obligations. The roles below are governance assignments; only Admin, Cashier, Inventory, and Super Admin are application roles in the current TypeScript role union.

Table 13. Governance responsibilities

Governance role	Owns / maintains	Approves / decides	Accountability
Client organization / accountable service owner	Legal organization was not supplied. Ira Pongasi is the client stakeholder named by the project owner; formal operational authority is not evidenced.	Accepts business changes, assigns owners, accepts residual risk.	Business impact, support capacity, and service direction.
Admin / store owner	Store configuration, product and staff accuracy, local access, daily reconciliation.	Routine account/store access, stock corrections, and purchase actions under local thresholds.	Store operation and correct, timely escalation.
Cashier	Accurate cart, payment, receipt, and shift handoff.	No role authority to approve own exceptions beyond assigned actions.	Actions performed under own credentials; prompt discrepancy report.
Inventory staff	Catalog, physical counts, movement records, and inventory reports.	Routine stock activity within role; Admin approves unusual changes per policy.	Count accuracy, conversion correctness, and evidence notes.
Super Admin	Owner invite-code governance.	Issue governed owner invitation codes.	Invite issuance and onboarding integrity; no tenant operations.
System Administrator	Supabase configuration, technical access, releases, logs, and recovery work.	Execute approved changes; emergency action under incident authority.	Technical recovery evidence, privileged access, and migration records.
Client service authority / IT Manager (if deployed)	No person or office was supplied. The client designates this role before production operation; project email is not a 24/7 service desk.	Approves major changes, emergency access, restoration, and service communications.	Service continuity and closure of corrective actions.

Governance role	Owns / maintains	Approves / decides	Accountability
Client/controller Privacy Contact / DPO	No individual was supplied. The responsible controller designates an authorized contact before personal-data processing; suspected breaches are escalated directly and immediately.	Leads and documents the breach assessment; the PIC retains the reportability and notification decision.	Transparent, documented privacy handling.
Developer / technical contributor	Source code and migrations under version control.	No routine production access; contributes reviewed changes.	Tests, review responses, and accurate technical documentation.

12. Decision rights and segregation of duties

Table 14. Decision and approval matrix

Decision	Prepares	Approves	Evidence
Create or change a user/store assignment	Admin	Authorized store owner / manager	Named user, role, store, approver, date, expiry where relevant.
High-impact stock correction	Inventory staff or Admin	Second authorized approver under local threshold	Count, reason, before/after, supporting reference.
Normal code or database change	Developer	Reviewer and release owner	Issue, pull request, tests, migration, release record.
Emergency technical change	System Administrator	IT Manager or delegated incident commander	Incident ID, reason, scope, rollback, time, retrospective review.
Restore or backup-retention change	System Administrator	IT Manager / System Owner	Restore scope, approvals, reconciliation, retention evidence.
Privacy request or disclosure	Privacy Contact with system support	Privacy authority under organization policy	Request, identity verification, decision, disclosure/correction/deletion evidence.

Where project staffing is too small for full separation, the System Owner records the conflict, appoints an independent reviewer for high-risk actions, and retains evidence. No single person should silently request, approve, implement, and close their own high-impact production change.

13. Access governance lifecycle

1. Request: document the user, business duty, role, store scope, start date, duration, and any privileged need.
2. Approve: Admin or designated owner validates identity and need; an independent approver reviews high-risk or cross-store access.
3. Provision: use the managed user function and invite flow selected for production; record the resulting role/store mapping.
4. Review: at least quarterly, compare active users, roles, and store assignments with current duties; record decisions and exceptions.
5. Revoke or change: remove access on separation, role change, compromise, or end of assignment; preserve transaction attribution and reconcile pending offline work.
6. Privileged access: restrict to named administrators, require MFA for Admin and Super Admin, approve and time-bound support access, and review after use.

Owner registration path in current project code: a Super Admin generates a one-time owner invitation code; the initial owner enters it, submits the registration form, and confirms email before signing in. The public production web route is available, but the deployed invite function, authorization rules, user recovery path, and production identity settings were not tested; use only approved accounts and verify these controls before relying on them.

14. Data and privacy governance

The deploying organization determines why personal information is collected, provides the required notice, assigns a Privacy Contact, approves retention, handles rights requests, and assesses incidents. Kodigo can contain names,

email addresses, roles, store assignments, supplier contact details, sales and stock activity, payment method and limited reference, audit events, error context, exports, and device/browser details when linked to a user.

Kodigo must not store full card numbers, PINs, one-time passwords, or wallet passwords. Ordinary cash checkout does not require customer identity; collect customer details only where a defined and approved feature requires them.

Privacy handling follows Republic Act No. 10173, its Implementing Rules and Regulations, and applicable National Privacy Commission (NPC) guidance. Report any suspected personal-data incident immediately to the deploying organization's designated Privacy Contact or Data Protection Officer (DPO) and the technical incident lead; do not wait for routine support hours or confirmed scope. The procedure below assigns notification accountability to the personal information controller (PIC). This document describes governance requirements and does not claim certification or verified legal compliance.

Breach assessment and notification procedure

1. Report and preserve: Any user, operator, or service provider who suspects a personal-data incident immediately contacts the designated Privacy Contact/DPO and technical incident lead. Record discovery time, known systems and data, affected people or records, actions taken, and securely preserve relevant logs and evidence.

2. Assess and decide: The deploying organization acting as PIC retains accountability for the notification decision. Its designated DPO/Privacy Contact documents the assessment and advises the authorized PIC decision-maker; the technical lead supplies the timeline, affected data and people, containment actions, and likely impact. Apply NPC Circular No. 2016-03, sections 11 and 13: assess whether sensitive personal information or information that could enable identity fraud was involved, whether it was likely acquired by an unauthorized person, and whether that acquisition is likely to create a real risk of serious harm. If uncertain, document the likely harm, whether notification would reduce risk, and the PIC's decision and rationale.

3. Notify: When notification is required, the PIC notifies the NPC within 72 hours of knowledge or reasonable belief, using information then available; notify affected data subjects within 72 hours, subject to the Circular's exemption or postponement rules. Do not wait for a complete investigation. Submit the full breach report within five days unless the NPC grants additional time, and retain proof of receipt and copies of notices.

4. Contain and review: Contain unauthorized access, revoke or reset affected credentials, preserve transaction attribution, and track corrective actions. Any delay, exemption, or postponement must follow the Circular and applicable NPC process; where section 17(C) prohibits delay, notify within the 72-hour period on available information. Complete a documented post-incident review.

Official references: Republic Act No. 10173; National Privacy Commission Implementing Rules and Regulations; NPC Breach Reporting; NPC Circular 16-03

Table 15. Privacy governance fields to complete

Privacy area	Documented status	Operational rule
Responsible organization	Ira Pongasi is the named client stakeholder; the legal organization name was not supplied.	Use synthetic data only until the responsible organization/controller is identified.
Privacy Contact / DPO	No individual or direct contact details were supplied.	The responsible controller designates the contact before personal-data processing; send suspected breach reports directly to that contact immediately.
Project support contact	Evon Christian P Vergara — vergaraevon@gmail.com; support hours are not formally established.	Project support only; not the client's legal Privacy Contact or an on-call service desk.
Retention and rights requests	No production retention schedule or rights-request channel was verified.	Do not load live personal information until the controller sets retention, access, correction/deletion, and notice processes.
Breach notification authority	The controller decides whether statutory notification is required.	The PIC makes and records the notification decision using NPC Circular 16-03 criteria; the designated DPO/Privacy Contact leads the assessment. For notifiable breaches, follow the 72-hour notice and five-day full-report requirements. The responsible organization and named contact remain unverified.

Data classification and protection levels

The table sets project-level handling requirements for data types evidenced in Kodigo. It does not assert that production provider settings, encryption configuration, or retention schedules were independently verified.

Data item	Classification	Required protection level	Retention and disposal
Approved public-facing product or service information and published user guidance	Public	Release only after owner review. Exclude personal data, account or store identifiers, transaction details, and secrets.	Review while published; withdraw obsolete copies.
Non-public product catalog, store configuration, operating procedures, and aggregated non-identifying operational summaries	Internal	Limit to authenticated users with a business need; share only through approved channels; do not place on public drives or personal email.	Keep only while operationally needed; remove stale copies.
User names and email addresses, roles and store assignments, supplier contacts, and device/browser details linked to a user	Confidential	Restrict by role and assigned store; minimize collection and exports; allow access only to authorized users.	The controller sets purpose-based retention before live personal-data use.
Sales and stock activity, purchase records, receipts, reports, audit events, support records, error context, and exports	Confidential	Use least-privilege and store-scoped access; limit exports; preserve transaction attribution and auditability.	The controller sets retention; securely dispose of obsolete copies after any applicable hold.
Passwords, invite/reset tokens, TOTP setup material, service-role keys, database exports, and backup copies	Restricted	Limit to authorized system operators; keep secrets server-side, never in browser bundles, logs, tickets, screenshots, or public storage; protect backup copies under approved provider controls.	Rotate or revoke exposed secrets; retain backups only under an approved recovery plan.
Full payment-card numbers, PINs, one-time passwords, and wallet passwords	Prohibited (not stored)	Do not collect or store. If encountered, stop routine handling and escalate through the incident process without copying or redistributing the data.	Do not retain; follow the incident and privacy process if unexpectedly encountered.

Related owner-issued policies: Acceptable Use Policy | BYOD Policy | Kodigo User Manual

15. Risk management

Table 16. Initial project risk register

Risk / evidence	Likelihood / impact	Potential effect	Mitigation, owner, and status
Migration or live database differs from current project code	High / High	Policies, columns, or functions may be missing or inconsistent.	Compare deployed migration ledger, schema, policies, grants, functions, and triggers before releases. Owner: System Administrator. / Status: Open — production backend state not verified.
Offline queue conflict or replay failure	Medium / High	A pending sale or stock change may be duplicated, rejected, or stale.	Use synthetic test cases; reconcile pending queue before retry; never clear browser data while work is pending. Owner: Admin + technical owner. Status: Open — limited conflict handling.
Privileged account compromise or TOTP not enforced	Medium / High	Unauthorized account, invite, or data changes.	Owner confirms TOTP is required and implemented for Admin/Super Admin; source includes enrollment and AAL2 checks. The migration has an AAL1 path without a verified factor, so the deployed first-factor gate remains uninspected. Owner: client service authority. / Status: Open — production enforcement not inspected.
Backup or restore path unavailable	Medium / High	Sales, stock, and audit history may not be recoverable.	Confirm provider backup plan, restricted access, retention, and an isolated restore rehearsal. Owner: System Administrator. / Status: Open — production plan and restore evidence not supplied.

Risk / evidence	Likelihood / impact	Potential effect	Mitigation, owner, and status
Vulnerable dependency or delayed patch	Medium / High	Known weakness may enable compromise or disruption.	Review advisories weekly and before release; prioritize critical fixes within 24 hours and high fixes within 7 days. Owner: technical maintainer. / Status: Open — no automated patch status verified.
Personal information exposed or retained without a controller process	Medium / High	Privacy harm, legal reporting, or rights-request failure.	Use synthetic demo data; identify controller/Privacy Contact and retention before live data; direct immediate breach escalation. Owner: client/controller. Status: Open — organization/contact not supplied.
Redacted screenshot still contains identifying or transaction detail	Low / Medium	Unintended disclosure in academic distribution.	Review each embedded figure at rendered size; mask identifiers and use only synthetic/demo data; limit distribution. Owner: Document Owner. Status: Review required before wider public use.

16. Change, release, and configuration management

Table 17. Naming, coding, metadata, and release standards

Area	Required project standard
Source of truth and database changes	Treat the target project's applied migration ledger as authoritative; add ordered migrations and never rewrite an applied migration. Review data impact, access policy, rollback, and documentation together.
Naming conventions	Database objects use snake_case; React components use PascalCase; hooks and functions use camelCase; constants use UPPER_SNAKE_CASE; routes use lowercase kebab-case. Use descriptive names; abbreviations only for established terms.
Folder and file taxonomy	Keep pages, components, stores, libraries, database migrations, Edge Functions, tests, and documentation in their existing feature-appropriate folders. Use filenames that identify feature and purpose; do not store secrets or live exports with source files.
Metadata and versioning	Every release record includes version, date, author, reviewer, issue/change reference, environment, migration range, test evidence, approver, and rollback reference. Mark environment and synthetic/live data status on test records.
Branch and review model	Use short-lived feature/<ticket>-<slug> or fix/<ticket>-<slug> branches from main; submit a reviewed change request; do not push directly to a production release. Branch protection is not verified in the current project host.
Code style and formatting	Follow TypeScript/React conventions already used in the project, small focused functions, explicit validation, safe error messages, and no secrets in browser code. Run ESLint, TypeScript typecheck, and build; no separate Prettier configuration is present.
Testing and vulnerability management	Run npm ci, typecheck, lint, build, and isolated integration tests before release. Review dependency advisories weekly and before each release; record severity, affected version, owner, remediation, and retest. No automated scanner or live patch status was verified.
Deployment and rollback	Confirm the target project, secrets, migration order, authorization tests, and smoke checks before release. Record the deployment and rollback reference. Restore schema/data only from a verified backup in an isolated replacement and reconcile before promotion.

Vulnerability review is a required release control; no automated scanner, monitoring integration, or live patch status was verified in the production configuration. Review dependency advisories weekly and before a release, record affected components and severity, test fixes in isolation, and preserve the change evidence.

Vulnerability triage and target remediation

Severity / trigger	Target containment or remediation	Evidence / owner
Critical / actively exploited	Contain immediately; target a verified fix or safe disablement within 24 hours.	Incident and change record; technical maintainer, with client service authority.
High	Target remediation within 7 calendar days.	Advisory, affected version, test and release record; technical maintainer.
Medium	Target remediation within 30 calendar days or document a compensating control.	Risk acceptance and planned release date; Project Owner / technical maintainer.

Severity / trigger	Target containment or remediation	Evidence / owner
Low	Include in the next planned maintenance release, normally within 90 days.	Monthly review record and version check; technical maintainer.

17. Incident management and escalation

The ITIL-aligned workflow logs, categorizes, assesses impact and urgency, assigns priority, diagnoses, escalates when needed, validates recovery, and records lessons. Tier 0 and Tier 1 handle self-check and store impact; Tier 2 investigates technical faults; Tier 3 coordinates major, privacy, vendor, or emergency decisions.

Incident response workflow

1. **Report and log:** Record the reporter, time, store, impact, evidence, and current status.
2. **Categorize and prioritize:** Assess impact and urgency, assign a P1-P4 priority, and name an incident owner.
3. **Diagnose:** Tier 0 or Tier 1 checks safe user and store causes. The Admin confirms impact and any safe workaround; unresolved technical faults go to Tier 2.
4. **Escalate major issues:** The IT Manager or incident lead coordinates a major response. The Privacy Contact assesses privacy impact, and a vendor is engaged when needed.
5. **Restore and validate:** Recover service, reconcile records, and confirm the result with the reporter.
6. **Record lessons:** Capture the cause, evidence, owner, due date, and corrective action for governance review.

Table 18. Proposed response targets for capstone operations

Tier / priority	Trigger	Target / action	Accountable contact
Tier 0 — self-help	Known how-to or non-impacting warning.	Use the manual and capture the exact message; do not repeat a pending transaction.	User / shift Admin.
Tier 1 — store operations	One user/register, cash discrepancy, or access issue.	Notify the store Admin, record the incident, and email the Project Owner. Support hours and response targets are not formally established; no guaranteed response SLA.	Store Admin; Project Owner Evon Christian P Vergara, vergaraevon@gmail.com.
Tier 2 — technical service	Multiple users/stores, failed synchronization, suspected data defect, or outage.	Stop unsafe retries, preserve references, and notify the Project Owner and designated technical operator through an approved channel. Availability and response target are not verified.	Project Owner / designated technical maintainer.
Tier 3 — security or privacy	Suspected account takeover, unauthorized disclosure, or personal-data breach.	Immediately contact the client/controller Privacy Contact through its official channel and notify the Project Owner; do not wait for routine support. The contact is not yet named.	Client/controller Privacy Contact (not yet named); Evon for project coordination.
Priority convention	P1 material service/security impact; P2 significant degraded work; P3 limited issue; P4 request.	Set priority from business/data impact, document the decision, update affected users through the existing client channel. Targets above are proposed operating guidance, not a contractual SLA.	Assigned incident owner.

Project support response hours are not formally established. The Project Owner email is not a 24/7 service desk or a guaranteed response-time commitment. The client organization must route privacy incidents directly to its designated Privacy Contact immediately, regardless of routine support availability.

18. Backup, recovery, audit, and monitoring responsibilities

Table 19. Operational ownership

Control activity / cadence	Responsible	Review / escalation	Evidence to retain
Each shift: reconcile cash closeout, pending offline work, and unusual stock events.	Store Admin; Cashier records assigned closeout.	Admin resolves routine mismatch; escalate unexplained or suspected fraud immediately.	Closeout, receipt/sale references, reconciliation note.
Daily during any pilot: review failed sync/error queue and provider backup status where available.	Designated technical maintainer / provider operator.	Project Owner; client service authority for material availability/data risk.	Dated review, unresolved issue, backup status, owner and due date.
Weekly: review incident/error patterns, audit/export events available to the organization, and dependency/security advisories.	Technical maintainer and Admin within assigned scope.	Project Owner; Privacy Contact for personal-data concern.	Review checklist, issue/change records, corrective actions.
Quarterly and on role change: review user roles, store memberships, and privileged access; rehearse restoration at least quarterly before production.	Admin and System Administrator.	Independent client service authority; privacy reviewer where data is involved.	Dated access roster, restore test, reconciliation results, approval.
Before each schema release and after an incident: preserve backup, migration, rollback, and incident timeline.	System Administrator / incident lead.	Release approver or client incident commander.	Backup reference, migration result, test evidence, timeline, recovery and lessons.

Proposed operating baseline for the deployed service: confirm provider backups, restricted backup access, at least 30-day retention where supported, a pre-migration backup, and quarterly isolated restore rehearsal. These are recommendations; the current production schedule, retention setting, and successful restore evidence were not verified.

19. User feedback and post-launch improvement

No interview, survey, pilot, or post-launch user-feedback results were supplied for this revision; no user findings are invented. The reviewed interface and code are technical observations, not user-reported evidence. The Project Owner records feedback sent to vergaraevon@gmail.com; a formal support response window has not been established.

1. Collect user feedback during onboarding, support incidents, and a scheduled post-launch review.
2. Group feedback into usability, reliability, data accuracy, access, and privacy themes; protect personal data in the record.
3. Prioritize changes by operational harm, user frequency, legal/privacy impact, and implementation effort.
4. Approve a change, assign an owner and due date, test in an isolated environment, and publish the release note or user instruction update.
5. After release, ask the reporting users whether the change solved the problem and record any remaining issue.

Feedback plan: collect qualitative task-interview notes and quantitative task-completion time/error counts during any authorized pilot; review weekly during pilot and monthly after stable operation. No structured feedback channel or pilot schedule has yet been verified.

User feedback evidence and post-launch prioritization

Evidence / method	Classification and result	Priority / response
Interviews, surveys, or usability sessions	No pre-launch user-study evidence was supplied; no user finding is claimed.	Collect qualitative task notes and quantitative completion time/error counts during an authorized pilot.

Evidence / method	Classification and result	Priority / response
Current interface/code review	Technical inspection only; not user-reported feedback.	Use to document implemented behavior and risks, not to assert user satisfaction.
Future pilot findings	Label each verified item Bug Report, Usability Issue, Feature Request, or Positive Feedback; retain date, role/store, and supporting evidence.	Apply MoSCoW: Must fix security/data-integrity blockers; Should address frequent workflow friction; Could improve convenience; Won't promise unsupported scope. Review weekly during pilot.

20. Documentation ownership, training, and review

This final owner-issued document set is Version 1.8 | 12 October 2026. Document owner: Evon Christian P Vergara. The peer-review audit and teacher revision-note incorporation are complete; no further document approval is pending. Deployment and operations remain subject to the evidence limits stated in this document.

- Review at least annually and after material changes to roles, privacy processing, sale lifecycle, inventory controls, hosting, or incident ownership.
- Use version history in the project current application source; record change summary, author/reviewer, approval, effective date, and replaced version.
- Keep controlled templates for access requests, risk reviews, incident records, restore tests, release approval, and user acknowledgment.
- Train Admins and Cashiers on sales and cash controls; Inventory staff on units, counts, and adjustments; privileged staff on access, MFA, privacy, and recovery.
- Retain attendance and practical competency evidence in an organization-approved restricted location.

User-facing procedures: Kodigo User Manual

21. Feasibility, rollout sequence, and resource plan

The public production web entry point is deployed at https://kodigo-blue.vercel.app/ and its login page was observed on 12 October 2026. Authenticated production workflows, Supabase project identity, applied migration state, role-group provisioning, backup configuration, client organization, Privacy Contact, test/UAT environments, rollout schedule, hosting costs, staffing, and user acceptance evidence remain unverified or not supplied. These are stated as evidence limits, not pending document approvals.

Table 20. Proposed rollout timeline

Milestone / phase	Completion evidence	Owner / target date status
1. Academic document and local-system baseline complete	Owner-issued academic baseline; repository source and public production login page reviewed; embedded screenshots redacted.	Evon Christian P Vergara — complete 12 Oct 2026.
2. Confirm client organization, privacy contact, and isolated test environment	Client-side roles, test project, migration ledger, data handling and contacts documented.	Not assigned; dates unverified.
3. Complete security, role/store, POS, offline, and restore tests	Dated test matrix, synthetic test outcomes, dependency review, restore rehearsal, risk disposition.	Not assigned; dates unverified.
4. Train users and conduct a controlled pilot if the client elects to proceed	Role-based practice, signed policy acknowledgments, support route, rollback and incident steps.	Not assigned; dates unverified.
5. Review pilot outcomes and decide next steps	Feedback log, incidents, measures, cost/value comparison, and documented continue/change/stop decision.	Not assigned; dates unverified.

Table 21. Indicative resource and budget plan

Resource / category	Availability / estimate status	Cost status
Project owner / development	Effort not estimated or approved.	Budget not supplied.
QA, security, and recovery testing	Required test activities identified; hours not estimated.	Budget not supplied.
Training and pilot support	Training may be needed if a client-authorized pilot is approved; hours not estimated.	Budget not supplied.
Devices and peripherals	Local demo uses the owner workstation; additional device needs are not verified.	Cost not supplied; hardware quotes are not available.
Hosting, email, and backup services	Public web deployment exists at https://kodigo-blue.vercel.app/; source uses Supabase. Provider plan, backend project identity, and backup configuration are not verified.	Actual hosting, email, and backup charges were not supplied; no current price is claimed.

ROI, approved labor hours/rate, costs, benefit baseline, and numeric target were not supplied; no realized ROI is claimed. Before any authorized pilot, set a baseline for reconciliation time, stock discrepancies, duplicate/rejected sales, and reordering rework, then compare results.

Appendix A. Redacted interface captures

These captures are from 15 September 2026 and show the interface at that time; they do not establish current production data, account provisioning, or control enforcement. Personal names, store labels, supplier identifiers, and contact fields are obscured. Example product and transaction values may be synthetic. The security-settings capture records the displayed account's TOTP status as "Not enabled" on that date; it does not override the owner-confirmed current MFA requirement or verify present enforcement.

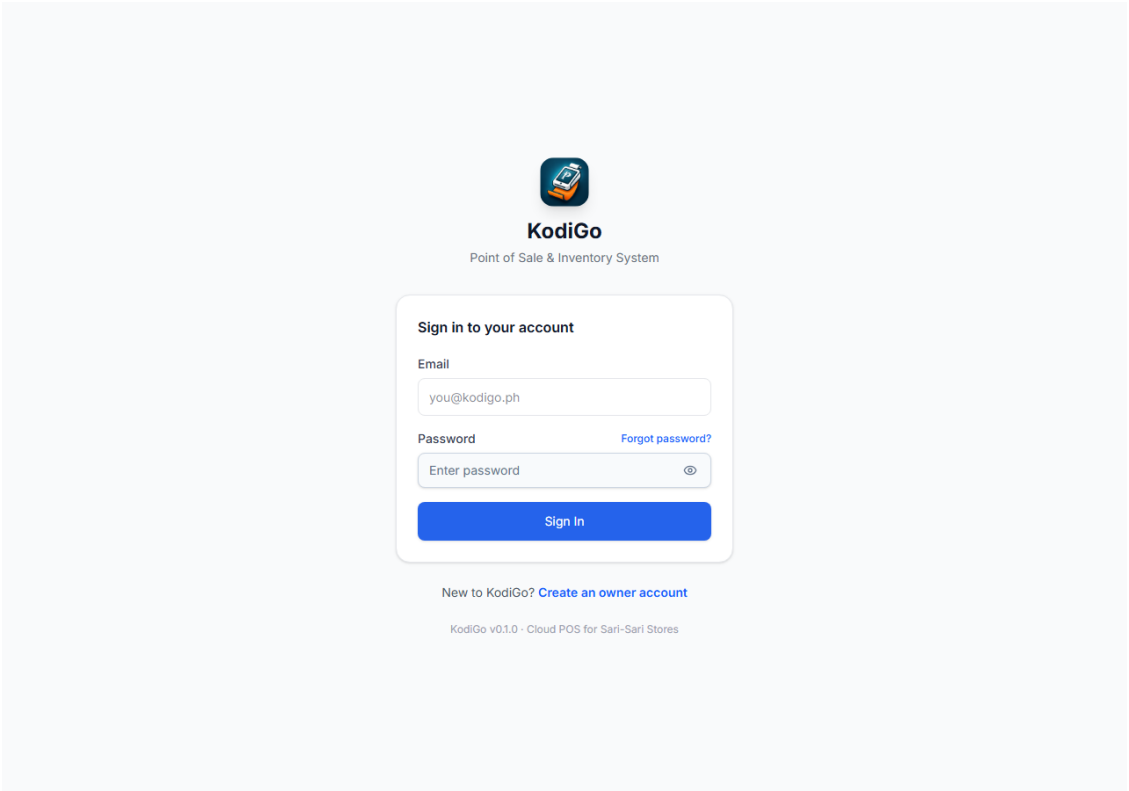


Figure 3. KodiGo sign-in screen (15 September 2026).

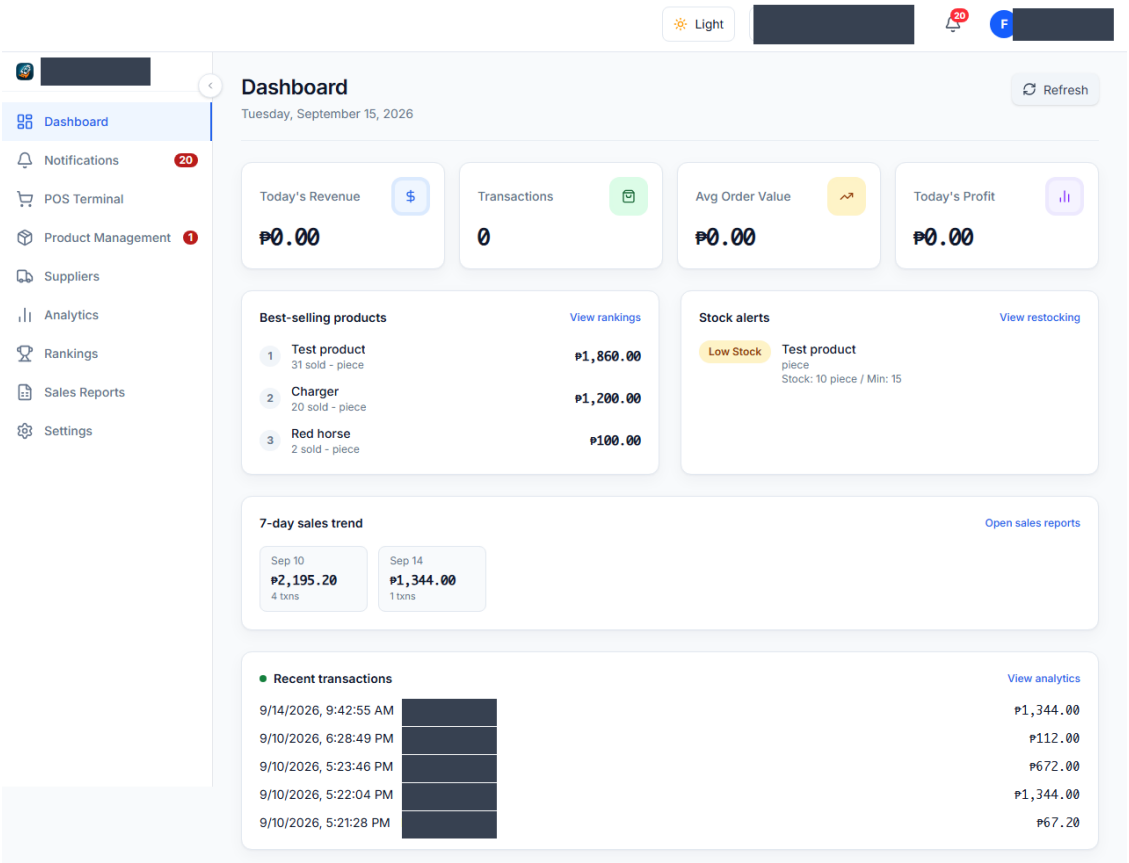


Figure 4. Dashboard; user, store, and transaction identities redacted (15 September 2026).

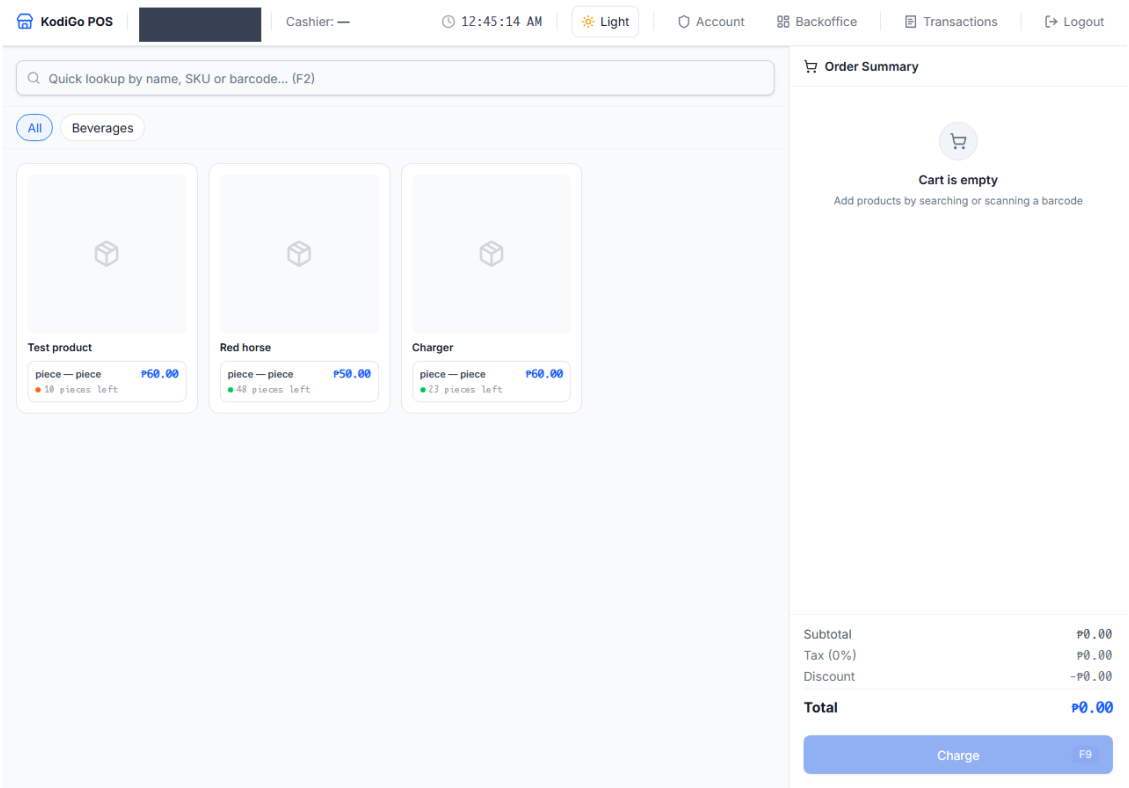


Figure 5. Point-of-sale terminal; store label redacted (15 September 2026).

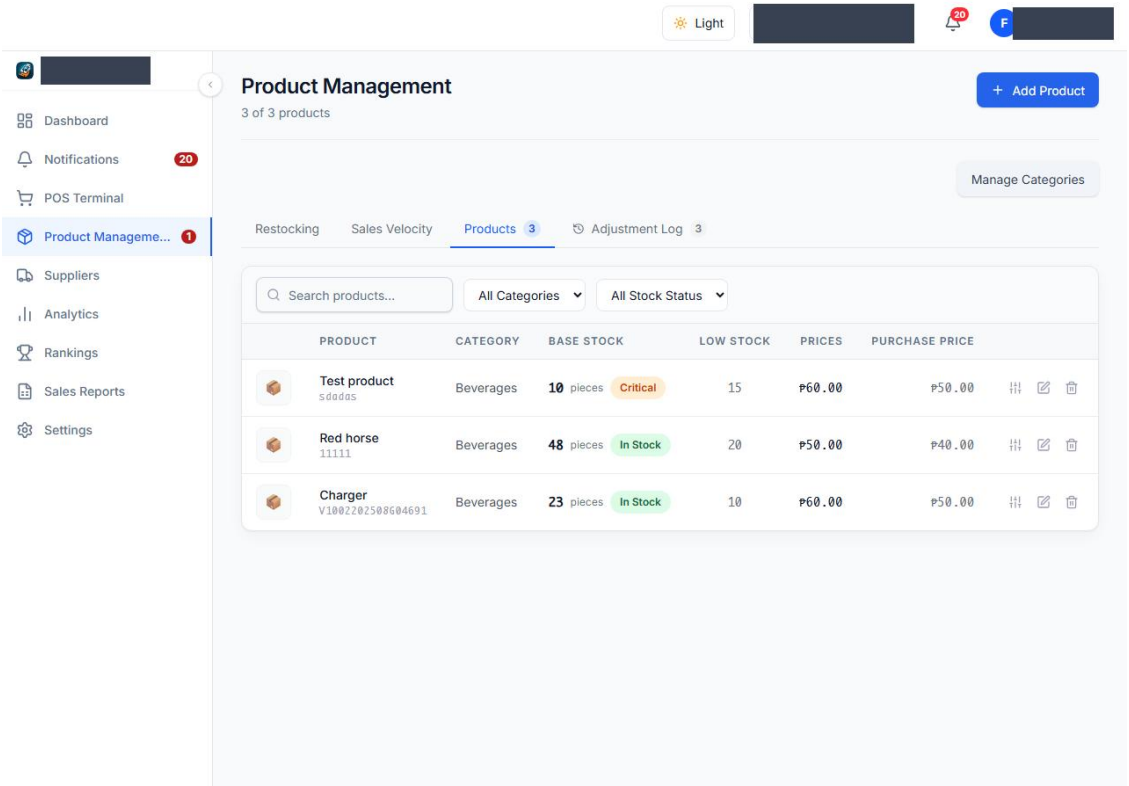


Figure 6. Inventory management; user and store identifiers redacted (15 September 2026).

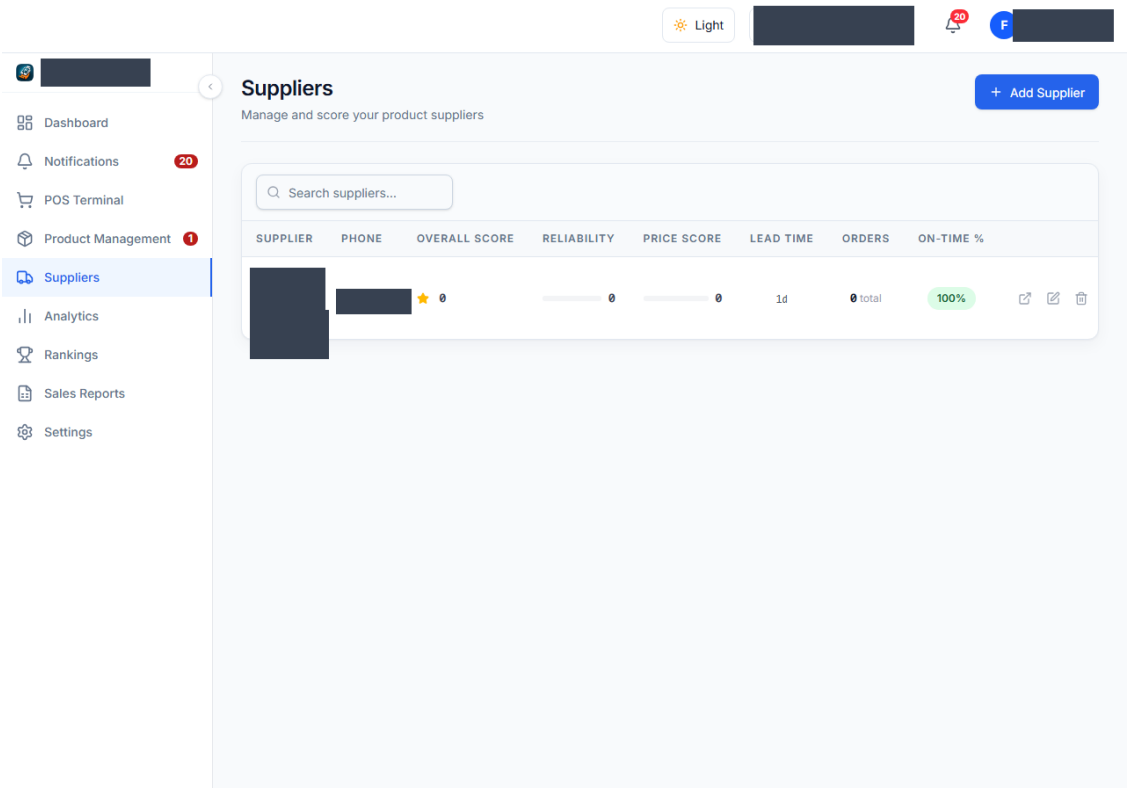


Figure 7. Supplier management; user, store, supplier, and contact identifiers redacted (15 September 2026).

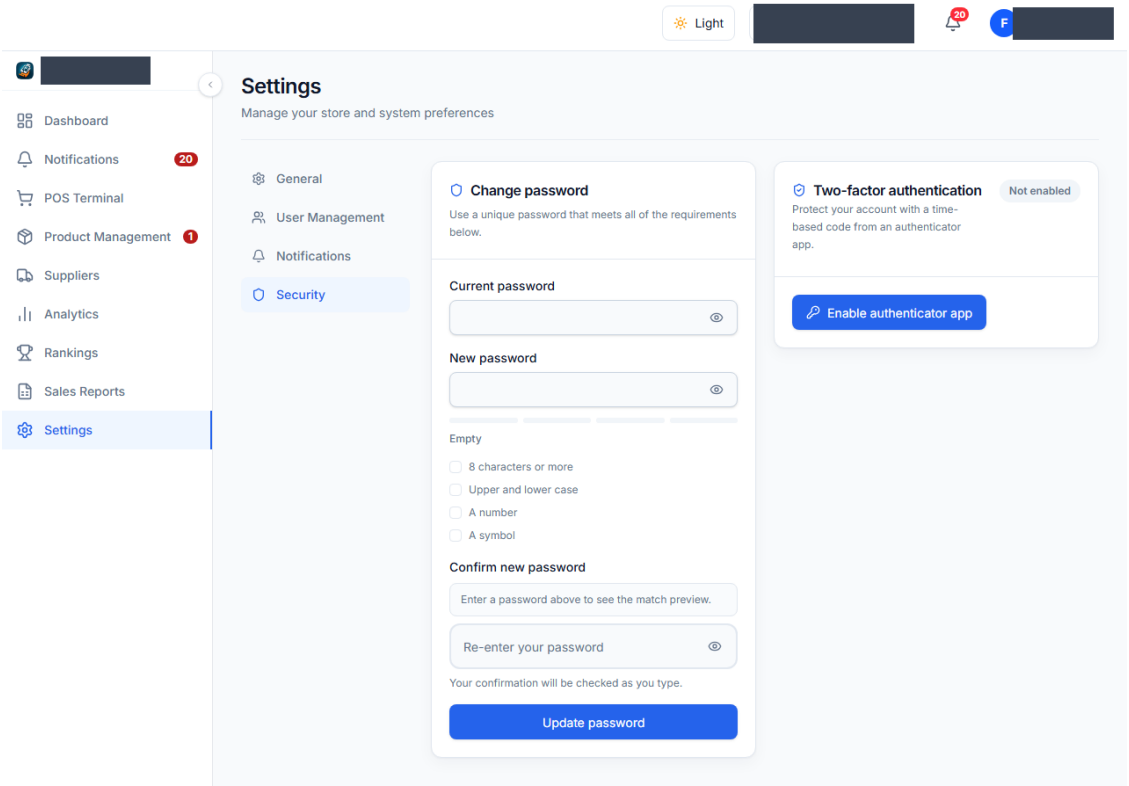


Figure 8. Security settings; displayed account showed TOTP "Not enabled" on 15 September 2026 (user and store identifiers redacted).